

# UniTorV E-Vote

Sistema di Voto Decentralizzato su Blockchain

## Documento di Definizione del Perimetro e Analisi dei Rischi

Framework di Riferimento: NIST CSF 2.0 / SP 800-53

**Versione:** 1.0

**Data:** 10 gennaio 2026

---

Questo documento definisce la superficie d'attacco, gli asset critici e i controlli di sicurezza implementati secondo gli standard internazionali.

## Indice

|          |                                                              |          |
|----------|--------------------------------------------------------------|----------|
| <b>1</b> | <b>Executive Summary</b>                                     | <b>2</b> |
| <b>2</b> | <b>Definizione del Perimetro (NIST ID.AM)</b>                | <b>2</b> |
| 2.1      | Asset In-Scope (Sotto Controllo Diretto) . . . . .           | 2        |
| 2.2      | Asset Out-of-Scope (Dipendenze Esterne) . . . . .            | 2        |
| <b>3</b> | <b>Analisi della Superficie d’Attacco</b>                    | <b>2</b> |
| 3.1      | Vettore Frontend (Web App) . . . . .                         | 2        |
| 3.2      | Vettore Smart Contract (Blockchain) . . . . .                | 3        |
| 3.3      | Vettore Utente (Endpoint) . . . . .                          | 3        |
| <b>4</b> | <b>Mappatura dei Controlli di Sicurezza (NIST SP 800-53)</b> | <b>4</b> |
| 4.1      | Identificazione e Protezione (ID & PR) . . . . .             | 4        |
| 4.2      | Rilevamento e Risposta (DE & RS) . . . . .                   | 4        |
| <b>5</b> | <b>Raccomandazioni e Next Steps</b>                          | <b>5</b> |

## 1 Executive Summary

Il sistema **UniTorV E-Vote** è una piattaforma ibrida (Web2 Frontend + Web3 Backend) progettata per gestire le votazioni del Consiglio di Amministrazione e dell'Assemblea Soci su rete Blockchain pubblica/permissioned.

L'architettura decentralizzata rimuove il singolo punto di fallimento (SPOF) per garantire l'integrità dei dati, ma introduce specifiche sfide di sicurezza relative alla gestione delle chiavi crittografiche e alla logica degli Smart Contract. Questo documento mappa tali sfide sui controlli del *National Institute of Standards and Technology* (NIST).

## 2 Definizione del Perimetro (NIST ID.AM)

Il perimetro di sicurezza definisce i confini entro i quali l'organizzazione ha controllo diretto e responsabilità.

### 2.1 Asset In-Scope (Sotto Controllo Diretto)

- **Interfaccia Web (Frontend):** Il codice HTML/CSS/JS ospitato su server web o IPFS che funge da client per l'interazione utente.
- **Smart Contract (Backend):** Il codice Solidity distribuito sulla Blockchain (indirizzo del contratto logico).
- **Logica di Business:** Le regole di quorum, durata votazioni e ruoli (CEO vs Soci) hard-coded nel contratto.
- **Accesso Amministrativo:** Il Wallet (indirizzo pubblico e chiave privata) in possesso esclusivo del CEO/Admin.

### 2.2 Asset Out-of-Scope (Dipendenze Esterne)

- **Infrastruttura Blockchain:** I nodi della rete (Ethereum/Polygon) che validano le transazioni. La sicurezza del consenso è delegata al protocollo sottostante.
- **Wallet Utenti (Soci):** La sicurezza delle chiavi private e dei seed phrase dei singoli soci (es. MetaMask sui device personali).
- **Endpoint Client:** Il sistema operativo e il browser utilizzato dall'utente finale.

## 3 Analisi della Superficie d'Attacco

La superficie d'attacco è suddivisa in tre vettori principali analizzati di seguito.

### 3.1 Vettore Frontend (Web App)

- **Phishing / DNS Spoofing:** Attaccanti potrebbero replicare l'interfaccia grafica per indurre gli utenti a firmare transazioni malevole.
- **XSS (Cross-Site Scripting):** Iniezione di script nel frontend per manipolare i dati visualizzati o le richieste di firma.
- **Supply Chain Attack:** Compromissione di librerie JavaScript esterne (es. Ethers.js) caricate da CDN.

### 3.2 Vettore Smart Contract (Blockchain)

- **Access Control Violation:** Tentativi di aggirare i modificatori `onlyCEO` per eseguire funzioni privilegiate.
- **Logic Errors:** Errori nel calcolo dei voti o nella gestione dei timestamp (`block.timestamp`).
- **Gas Limit DoS:** Creazione di loop infiniti o consumo eccessivo di risorse che rende il contratto inutilizzabile (Denial of Service).

### 3.3 Vettore Utente (Endpoint)

- **Compromissione Chiave Privata:** Furto delle credenziali del CEO, che comprometterebbe l'intera governance del sistema.
- **Man-in-the-Browser:** Malware sul dispositivo dell'utente che modifica i parametri della transazione prima della firma.

## 4 Mappatura dei Controlli di Sicurezza (NIST SP 800-53)

Di seguito vengono riportate le contromisure tecniche implementate nel codice, mappate sui codici di controllo NIST Cybersecurity Framework.

### 4.1 Identificazione e Protezione (ID & PR)

| ID NIST | Descrizione Controllo           | Implementazione in UniTorV                                                                                                                       |
|---------|---------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------|
| AC-3    | Access Enforcement              | Utilizzo di <code>modifier onlyCEO</code> e <code>onlySocio</code> in Solidity per bloccare transazioni non autorizzate a livello di protocollo. |
| IA-2    | Identification & Authentication | L'autenticazione avviene tramite firma digitale (ECDSA) verificata crittograficamente dalla Blockchain, eliminando le password centralizzate.    |
| SC-8    | Transmission Confidentiality    | Il frontend è servito via HTTPS. Le transazioni sono firmate localmente (client-side), quindi la chiave privata non viene mai trasmessa in rete. |
| SI-10   | Information Input Validation    | Controlli rigidi tramite <code>require()</code> nello Smart Contract (es. verifica duplicazione voto, scadenza temporale).                       |
| SA-11   | Developer Security Testing      | Verifica e pubblicazione del codice sorgente su Block Explorer (es. Etherscan) per audit pubblico.                                               |

### 4.2 Rilevamento e Risposta (DE & RS)

| ID NIST | Descrizione Controllo | Implementazione in UniTorV                                                                                                                     |
|---------|-----------------------|------------------------------------------------------------------------------------------------------------------------------------------------|
| AU-2    | Event Logging         | Emissione di eventi Blockchain ( <code>emit VotoRegistrato</code> ) che creano un registro immutabile, timestampato e consultabile per sempre. |
| AU-6    | Audit Review          | La Dashboard Amministratore include una sezione "Live Analytics" che legge direttamente dal ledger per rilevare anomalie.                      |
| CP-9    | System Backup         | Ridondanza intrinseca: il database è distribuito su migliaia di nodi globali. Non è necessario backup centralizzato.                           |
| IR-4    | Incident Handling     | <i>Raccomandazione:</i> Implementazione pattern <b>Emergency Stop</b> (Pausable) per bloccare il contratto in caso di vulnerabilità critica.   |

## 5 Raccomandazioni e Next Steps

Per garantire la piena conformità e sicurezza operativa, si raccomanda di:

1. **Cold Storage (CEO):** La chiave privata dell'amministratore deve essere custodita su un Hardware Wallet (Ledger/Trezor) e mai su un browser connesso permanentemente (Hot Wallet).
2. **Audit Professionale:** Sottoporre il codice Solidity a un audit di sicurezza da parte di terze parti prima del deploy in Mainnet.
3. **Decentralizzazione Frontend:** Ospitare i file dell'interfaccia utente su IPFS (InterPlanetary File System) per mitigare rischi di censura o attacchi al server web centralizzato.